

Instructor Guide — Teaching Complete Attack Chains

Scenario fittizio. Le chain non tecniche sono tabletop; le verifiche reali restano limitate all'ambiente di laboratorio autorizzato.

Il problema da evitare

L'esercizio sulla attack surface può facilmente diventare un elenco:

```
USB
phishing
reception
Wi-Fi
badge
scanner
```

Non basta.

Dopo una prima ipotesi chiedere:

Supponiamo che funzioni. Che cosa avete ottenuto esattamente? E come cambia la superficie disponibile?

Il modello è:

```
STARTING CONDITION
  ↓
CAPABILITY GAINED
  ↓
NEW ATTACK SURFACE
  ↓
NEXT HYPOTHESIS
  ↓
CONTROL
  ↓
RESULT
  ↓
NEXT DECISION
```

ASSUME SUCCESS

Per ragionare oltre il primo passo senza eseguire social engineering o physical testing, introdurre:

[A] ASSUMED SUCCESS FOR TABLETOP

Dire alla classe:

Per qualche minuto concediamo alla vostra chain che questo passaggio sia riuscito. Non significa che lo avete dimostrato. Serve soltanto a vedere cosa diventerebbe possibile dopo.

Questo separa:

VALIDATED
vs
HYPOTHETICAL

La domanda dopo ogni successo

Non chiedere subito:

E poi come lo attacchi?

Chiedere:

Cosa possiedi adesso che prima non possedevi?

Risposte concrete possono essere:

informazione
posizione fisica
accesso a una zona
accesso a una rete
identità autenticata
ruolo
sessione
nome di un servizio
conoscenza di una relazione
conoscenza di un processo
capacità di leggere un oggetto

Solo da quella capacità si costruisce il nodo successivo.

Esempio guidato — reception

Studente:

Entro dalla reception.

Risposta docente:

Entrare dove, precisamente?

Riformulare:

[A]
Sono riuscito ad arrivare in un'area
normalmente accessibile a un visitatore.

Poi:

Cosa cambia?

Possibili direzioni da far emergere:

- osservare il processo visitatori;
- capire quali aree richiedono accompagnamento;
- identificare informazioni esposte agli ospiti;
- acquisire contesto su sale, progetti, ruoli e fornitori;
- identificare controlli che impediscono di proseguire.

Evitare il salto:

sono in reception
→ rubo password
→ comprometto PC
→ comprometto rete

Ogni freccia deve essere giustificata.

Se emergono nome progetto e fornitore, chiedere:

Che capacità hai ottenuto?

Risposta:

CONOSCENZA DEL CONTESTO

Poi:

Quale nuova ipotesi rende più plausibile?

La chain prosegue dal risultato reale del nodo, non dal risultato desiderato.

Reception → process → identity

Possibile struttura tabletop:

```
[0] reception gestisce visitatori e fornitori
  ↓
[A] accesso a un'area visitatori
  ↓
[A] raccolta di contesto organizzativo
  ↓
[N] ipotesi su un processo di supporto o fornitore
  ↓
[A] assumiamo che il primo controllo fallisca
  ↓
? quale risultato concreto otteniamo?
```

Se uno studente risponde direttamente:

```
reset password
```

chiedere:

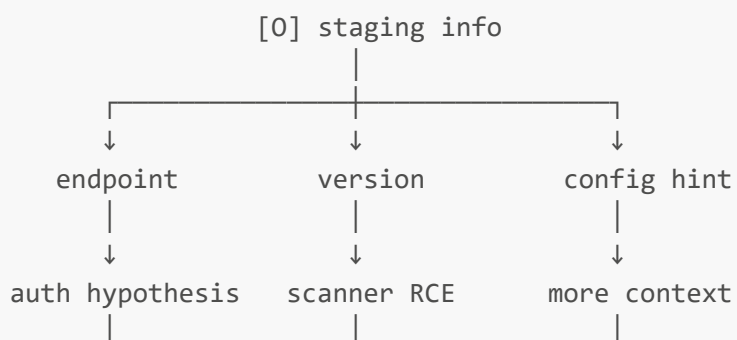
Quali passaggi stai saltando?

Far emergere possibili controlli concettuali:

```
verifica identità
MFA
callback
approvazione
ruolo autorizzato
```

Ogni controllo è un nodo possibile.

Una chain con rami



↓ ↓ ↓
[V] BFLA [X] no proof [N] later

La chain è quindi un grafo, non una sequenza obbligatoria.

Obiettivo finale

Ogni chain deve rispondere a una domanda del cliente.

Buoni obiettivi:

verificare se un customer supera il proprio authorization boundary

verificare se informazioni accessibili a un visitatore
cambiano significativamente la superficie disponibile

verificare se un controllo dichiarato interrompe una possibile attack path

Obiettivo poco utile:

compromettere tutto

Chain dimostrata e chain ipotetica

Tenere sempre separate:

DEMONSTRATED	HYPOTHESIZED
[O] service 8080	[A] accesso fisico
[O] endpoint scoperto	[A] contesto interno
[V] customer → admin stats	[N] processo vulnerabile

Nel report tecnico, la prima colonna può sostenere finding.

La seconda può sostenere threat scenario, futura area di assessment o limitation, ma non va raccontata come fatto.

Errori da interrompere

Studente:

Sono dentro la sede, quindi sono nella rete.

Domanda:

Quale passaggio collega accesso fisico e accesso di rete?

Studente:

Ho la guest, quindi vedo la corporate.

Domanda:

Cosa sappiamo sulla segmentazione?

Studente:

Lascio una USB e comprometto il PC.

Domanda:

Quanti passaggi stai comprimendo in quella freccia?

Studente:

Conosco il CEO, quindi una comunicazione funzionerà.

Domanda:

Quali controlli e comportamenti stai assumendo?

Studente:

Ho un IDOR, quindi scarico tutto il database.

Domanda:

Qual è l'impatto massimo realmente dimostrato?

Esercizio alla lavagna

Scrivere soltanto:

RECEPTION

Poi chiedere:

Cosa sappiamo realmente?

Scrivere i soli fatti.

Poi:

Qual è una prima ipotesi?

Aggiungere un nodo.

Poi:

Supponiamo che funzioni. Che cosa abbiamo guadagnato?

Aggiungere la capability.

Continuare per 5 o 6 nodi.

Ogni volta che compare un salto:

Che cosa rende valida questa freccia?

Questa frase può diventare il mantra dell'esercizio.

Valutazione

Non premiare la chain più lunga.

Premiare:

1. assenza di salti logici;
2. capacità di nominare la capability acquisita;
3. identificazione dei controlli;
4. distinzione assumed vs validated;
5. capacità di ramificare;
6. capacità di fermarsi;
7. collegamento all'obiettivo business;
8. corretta limitazione dell'impatto.

Output

Ogni gruppo produce:

- due attack chain;
- almeno 4 o 5 nodi;
- almeno un branch;
- almeno un controllo;
- almeno uno stop;
- etichette [O], [V], [A], [N], [X];
- maximum demonstrated impact;
- maximum hypothesized impact.

Una delle due chain deve integrare almeno un elemento tecnico del laboratorio.

Collegamento al report

Non inserire una chain tabletop nel report come se fosse successa.

Distinguere:

CONFIRMED FINDING

ciò che è stato validato

ATTACK PATH / THREAT SCENARIO

ciò che potrebbe diventare possibile

se determinati prerequisiti fossero verificati

Questa distinzione collega threat modeling, penetration testing e reporting senza confonderli.